SECURITIES AND EXCHANGE COMMISSION

17 CFR Parts 240, 248, 270, and 275

[Release Nos. 34-100155; IA-6604; IC-35193; File No. S7-05-23]

RIN 3235-AN26

Regulation S-P: Privacy of Consumer Financial Information and Safeguarding Customer Information

AGENCY: Securities and Exchange Commission.

ACTION: Final rule.

SUMMARY: The Securities and Exchange Commission ("Commission" or "SEC") is adopting rule amendments that will require brokers and dealers (or "broker-dealers"), investment companies, investment advisers registered with the Commission ("registered investment advisers"), funding portals, and transfer agents registered with the Commission or another appropriate regulatory agency ("ARA") as defined in the Securities Exchange Act of 1934 ("transfer agents") to adopt written policies and procedures for incident response programs to address unauthorized access to or use of customer information, including procedures for providing timely notification to individuals affected by an incident involving sensitive customer information with details about the incident and information designed to help affected individuals respond appropriately. In addition, the amendments extend the application of requirements to safeguard customer records and information to transfer agents; broaden the scope of information covered by the requirements for safeguarding customer records and information and for properly disposing of consumer report information; impose requirements to maintain written records documenting compliance with the amended rules; and conform annual privacy notice delivery

provisions to the terms of an exception provided by a statutory amendment to the Gramm-Leach-Bliley Act ("GLBA").

DATES: *Effective date*: This rule is effective [INSERT DATE 60 DAYS AFTER DATE OF PUBLICATION IN THE *FEDERAL REGISTER*].

Compliance date: The applicable compliance dates are discussed in section II.F of this rule.

FOR FURTHER INFORMATION CONTACT: Emily Hellman, James Wintering, Special Counsels; Edward Schellhorn, Branch Chief; Devin Ryan, Assistant Director; John Fahey, Deputy Chief Counsel; Emily Westerberg Russell, Chief Counsel; Office of Chief Counsel, Division of Trading and Markets, (202) 551-5550; Kevin Schopp, Senior Special Counsel; Moshe Rothman, Assistant Director; Office of Clearance and Settlement, Division of Trading and Markets, (202) 551-5550, Susan Ali and Andrew Deglin, Counsels; Michael Khalil and Y. Rachel Kuo, Senior Counsels; Blair Burnett and Bradley Gude, Branch Chiefs; or Brian McLaughlin Johnson, Assistant Director, Investment Company Regulation Office, Division of Investment Management, (202) 551-6792, Securities and Exchange Commission, 100 F Street NE, Washington, DC, 20549.

SUPPLEMENTARY INFORMATION: The Commission is adopting amendments to 17 CFR 248.1 through 248.100 ("Regulation S-P") under Title V of the GLBA [15 U.S.C. 6801 through 6827], the Fair Credit Reporting Act ("FCRA") [15 U.S.C. 1681 through 1681x], the Securities Exchange Act of 1934 ("Exchange Act") [15 U.S.C. 78a *et seq*.], the Investment Company Act of 1940 ("Investment Company Act") [15 U.S.C. 80a-1 *et seq*.], and the Investment Advisers Act of 1940 ("Investment Advisers Act") [15 U.S.C. 80b-1 *et seq*.].

TABLE OF CONTENTS

I. INTRODUCTION AND BACKGROUND 5
II. DISCUSSION 15
A. Incident Response Program Including Customer Notification 16
1. Assessment 21
2. Containment and Control 22
3. Notice to Affected Individuals 23
4. Service Providers 69
B. Scope of Safeguards Rule and Disposal Rule 92
1. Scope of Information Protected 92
2. Extending the Scope of the Safeguards Rule and the Disposal Rule to Cover All Transfer Agents 100
3. Maintaining the Current Regulatory Framework for Notice-Registered Broker-Dealers 119
C. Recordkeeping 121
D. Exception from Requirement to Deliver Annual Privacy Notice 126
E. Existing Staff No-Action Letters and Other Staff Statements 128
F. Compliance Period 129
III. OTHER MATTERS 132
IV. ECONOMIC ANALYSIS 133
A. Introduction 133
B. Broad Economic Considerations 140
C. Baseline 150
1. Safeguarding Customer Information: Risks and Practices 155
2. Regulations and Guidelines 160
3. Market Structure 185
D. Benefits and Costs of the Final Rule Amendments 199
1. Written Policies and Procedures 203
2. Extending the Scope of the Safeguards Rule and the Disposal Rule 268
3. Recordkeeping 282
4. Exception from Annual Notice Delivery Requirement 284
E. Effects on Efficiency, Competition, and Capital Formation 285
F. Reasonable Alternatives Considered 296
1. Reasonable Assurances from Service Providers 296
2. Lower Threshold for Customer Notice 299
3. Encryption Safe Harbor 300
4. Longer Customer Notification Deadlines 302
5. Broader National Security and Public Safety Delay in Customer Notification 303
V. PAPERWORK REDUCTION ACT 305
A. Introduction 305
B. Amendments to the Safeguards Rule and Disposal Rule 308
VI. FINAL REGULATORY FLEXIBILITY ACT ANALYSIS 314

A. Need for, and Objectives of, the Final Amendments 314
B. Significant Issues Raised by Public Comments 315
C. Small Entities Subject to Final Amendments 319
D. Projected Reporting, Recordkeeping, and Other Compliance Requirements 321
E. Agency Action to Minimize Effect on Small Entities 326
STATUTORY AUTHORITY 328

I. INTRODUCTION AND BACKGROUND

Regulation S-P is a set of privacy rules adopted pursuant to the GLBA and the Fair and Accurate Credit Transactions Act of 2003 ("FACT Act") that govern the treatment of nonpublic personal information about consumers by certain financial institutions.[1] The Commission is adopting rule amendments that are designed to modernize and enhance the protections that Regulation S-P provides by addressing the expanded use of technology and corresponding risks that have emerged since the Commission originally adopted Regulation S-P in 2000. The amendments in particular update the requirements of the "safeguards" and "disposal" rules. The safeguards rule requires brokers, dealers, investment companies,[2] and registered investment advisers to adopt written policies and procedures that address administrative, technical, and physical safeguards to protect customer records and information.[3] The disposal rule, which applies to transfer agents registered with the Commission in addition to the institutions covered by the safeguards rule, requires proper disposal of consumer report information.[4] In addition, under Regulation Crowdfunding, funding portals must comply with the requirements of Regulation S-P as they apply to brokers.[5] Thus, funding portals will also be required to comply with the applicable amendments to Regulation S-P adopted in this release.

---

1 *See* 17 CFR 248.1.

2 Regulation S-P applies to investment companies as the term is defined in section 3 of the Investment Company Act (15 U.S.C. 80a-3), whether or not the investment company is registered with the Commission. *See* 17 CFR 248.3(r). Thus, a business development company, which is an investment company but is not required to register as such with the Commission, is subject to Regulation S-P. Similarly, employees' securities companies – including those that are not required to register under the Investment Company Act – are investment companies and are, therefore, subject to Regulation S-P. By contrast, issuers that are excluded from the definition of investment company – such as private funds that are able to rely on section 3(c)(1) or 3(c)(7) of the Investment Company Act – are not subject to Regulation S-P.

3 17 CFR 248.30(a). References in this release to "rule 248.30" are to 17 CFR 248.30.

4 Rule 248.30(b).

5 *See* 17 CFR 227.403(b). Accordingly, unless otherwise stated (for example, *see infra* sections IV and V), references in this release to "brokers" or "broker-dealers" include funding portals.

The final Regulation S-P amendments are needed to provide enhanced protection of customer or consumer information and help ensure that customers of covered institutions receive timely and consistent notifications in the event of unauthorized access to or use of their information.[6] In evaluating amendments to Regulation S-P, we have considered developments in how firms obtain, share, and maintain individuals' personal information since the Commission originally adopted Regulation S-P, which correspond with an increasing risk of harm to individuals.[7] This environment of expanded risks and the importance of reducing or mitigating the potential for harm also supports our amendments to Regulation S-P.

In March 2023, the Commission proposed amendments to Regulation S-P.[8] In particular, the proposed amendments would amend the safeguards rule to require any broker or dealer, investment company, registered investment adviser, or transfer agent (collectively, "covered

---

6 *See* Proposing Release at section II.A.4.

7 *See*, *e.g.*, Federal Bureau of Investigation, 2022 Internet Crime Report (Mar. 27, 2023), at 7-8, *available at*: https://www.ic3.gov/Media/PDF/AnnualReport/2022_IC3Report.pdf (stating that the FBI's Internet Crime Complaint Center received 800,944 complaints in 2022 (an increase from 351,937 complaints in 2018). The complaints included 58,859 related to personal data breaches (an increase from 50,642 breaches in 2018)); the Financial Industry Regulatory Authority ("FINRA"), *2022 Report on FINRA's Examination and Risk Monitoring Program: Cybersecurity and Technology Governance* (Feb. 2022), *available at:* https://www.finra.org/rules-guidance/guidance/reports/2022-finras-examination-and-risk-monitoring-program (noting increased number and sophistication of cybersecurity attacks and reminding firms of their obligations to oversee, monitor, and supervise cybersecurity programs and controls of third-party vendors); Office of Compliance Inspections and Examinations (now the Division of Examinations) ("EXAMS"), Risk Alert, *Cybersecurity: Safeguarding Client Accounts against Credential Compromise* (Sept. 15, 2020), *available at* https://www.sec.gov/files/Risk%20Alert%20-%20Credential%20Compromise.pdf (describing increasingly sophisticated methods used by attackers to gain access to customer accounts and firm systems). This Risk Alert, and any other Commission staff statements represent the views of the staff. They are not a rule, regulation, or statement of the Commission. Furthermore, the Commission has neither approved nor disapproved their content. These staff statements, like all staff statements, have no legal force or effect. They do not alter or amend applicable law; and they create no new or additional obligations for any person.

8 *See* Regulation S-P: Privacy of Consumer Financial Information and Safeguarding Customer Information, Securities Exchange Act Release No. 97141 (Mar. 15, 2023) [88 FR 20616 (Apr. 6, 2023)] ("Proposing Release" or "proposal"). The Commission voted to issue the Proposing Release on Mar. 15, 2023. The release was posted on the Commission website that day, and comment letters were received beginning the same day. The comment period closed on June 5, 2023. We have considered all comments received since Mar. 15, 2023.

institutions") to develop, implement, and maintain written policies and procedures for an incident response program reasonably designed to detect, respond to, and recover from unauthorized access to or use of customer information. The proposal included a further requirement that, as part of this incident response program, covered institutions would provide notices to individuals whose sensitive customer information was, or is reasonably likely to have been, accessed or used without authorization as soon as practicable, but not later than 30 days, after becoming aware that the incident occurred or is reasonably likely to have occurred. The proposed notice requirement included provisions that addressed the use of service providers by covered institutions and included a provision that would permit covered institutions to delay providing notice after receiving a written request from the United States Attorney General ("Attorney General") that this notice poses a substantial risk to national security.

The Commission also proposed other amendments to Regulation S-P to enhance the protection of customers' nonpublic personal information. The proposed amendments included provisions to expand the scope of the protections of the safeguards and disposal rules, including extending the safeguards rule to transfer agents. The proposed amendments also included requirements for covered institutions to maintain written records documenting compliance with the proposed amended rules. Finally, the Commission proposed amendments to conform annual privacy notice delivery provisions to the terms of an exception provided by a statutory amendment to the GLBA.

The Commission received comment letters on the proposal from a variety of commenters, including financial services firms and their service providers, law firms, investor advocacy groups, professional and trade associations, public policy research institutes, academics, and

interested individuals.[9] Most individual and public interest group commenters and some industry groups generally supported the proposed amendments.[10] A few commenters urged the Commission to consider taking additional steps to strengthen the proposed requirements, for example, by shortening the period for customer notification.[11] Many industry commenters expressed concern with specific elements of the proposed amendments, however, suggesting that these amendments would pose operational difficulties.[12]

Comments on specific aspects of the proposed amendments focused on a few key themes. First, commenters urged the Commission to take a more holistic regulatory approach to harmonize the proposed amendments with other Commission rules and proposals to avoid

---

9 The comment letters on the proposal are available at https://www.sec.gov/comments/s7-05-23/s70523.htm.

10 *See, e.g.,* Comment Letter of the Investment Adviser Association (June 5, 2023) ("IAA Comment Letter 1"); Comment Letter of the Investment Company Institute (May 23, 2023) ("ICI Comment Letter 1"); Comment Letter of Better Markets (June 5, 2023) ("Better Markets Comment Letter"); Comment Letter of North American Securities Administrators Association (May 22, 2023) ("NASAA Comment Letter"). Some commenters suggested more tailored requirements for smaller covered institutions. *See, e.g.*, IAA Comment Letter 1; Comment Letter of the Securities Transfer Association (June 2, 2023) ("STA Comment Letter 2"); Comment Letter of the Committee of Annuity Insurers (June 5, 2023) ("CAI Comment Letter"). As discussed in more detail below, the final amendments apply to all covered institutions because entities of all sizes are vulnerable to the types of data security breach incidents we are trying to address. *See infra* section VI.

11 *See, e.g.,* Better Markets Comment Letter.

12 *See, e.g.,* Comment Letter of the Securities Industry and Financial Markets Association, et al. (June 5, 2023) ("SIFMA Comment Letter 2"); Comment Letter of the Financial Services Institute (May 22, 2023) ("FSI Comment Letter"); Comment Letter of Federated Hermes, Inc. (June 6, 2023) ("Federated Comment Letter").

creating redundant, overlapping, or conflicting obligations for covered institutions.[13] We have modified the rule from the proposal to address comments.[14]

For example, covered institutions may be required to adopt written policies and procedures on similar issues under other provisions of the Federal securities laws.[15] A covered institution can, however, adopt a single set of policies and procedures covering Regulation S-P and other rules, provided that the policies and procedures meet the requirements of each rule.[16] Additionally, we have changed the proposed requirement to delay providing customer notices

---

13 *See, e.g.,* IAA Comment Letter 1; ICI Comment Letter 1; Comment Letter of Nasdaq Stock Market LLC (June 2, 2023) ("Nasdaq Comment Letter"). Commenters also raised these concerns about other proposed rulemakings that the Commission has not adopted. *See*, *e.g.*, Comment Letter of the Investment Adviser Association (June 17, 2023) ("IAA Comment Letter 2"); ICI Comment Letter 1. Other commenters requested more specific guidance regarding how the various policies and procedure requirements in other Commission proposals would interact with each other. *See, e.g.*, CAI Comment Letter; SIFMA Comment Letter 2; IAA Comment Letter 2. To the extent that those proposals are adopted, the baseline in those subsequent rulemakings will reflect the existing regulatory requirements at that time.

14 Since the publication of the proposing release, the Commission adopted new rules to enhance and standardize disclosures regarding cybersecurity risk management, strategy, governance, and incidents by public companies that are subject to the reporting requirements of the Securities Exchange Act of 1934 ("Public Company Cybersecurity Rules"). *See* Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure, Securities Act Release No. 11216 (July 26, 2023) [88 FR 51896 (Aug. 4, 2023)].

15 *See*, *e.g.*, 15 U.S.C. 80b-4a (requiring each adviser registered with the Commission to have written policies and procedures reasonably designed to prevent misuse of material non-public information by the adviser or persons associated with the adviser); 17 CFR 270.38a-1(a)(1) (requiring investment companies to adopt compliance policies and procedures); 275.206(4)-7(a) (requiring investment advisers to adopt compliance policies and procedures); and Regulation S-ID, 17 CFR part 248, subpart C (requiring financial institutions subject to the Commission's jurisdiction with covered accounts to develop and implement a written identity theft prevention program that is designed to detect, prevent, and mitigate identity theft in connection with covered accounts, which must include, among other things, policies and procedures to respond appropriately to any red flags that are detected pursuant to the program).

16 Two commenters addressed the proposal's application to dually-registered investment advisers and broker-dealers or firms operating both business models (collectively, "dual registrants"). One of these commenters stated that the proposed amendments to Regulation S-P allow for streamlining of process because they would apply uniformly to broker-dealers and investment advisers. FSI Comment Letter. The other commenter addressed collectively other Commission cyber proposals and the proposed amendments to Regulation S-P. The commenter stated that these proposals collectively would involve significant burden for a dual registrant to bring both broker-dealer and investment adviser entities into compliance, urging the Commission to provide an extended compliance period for all of the proposed rules to provide time for dual registrants to come into compliance and "identify some synergies that might make compliance more effective and economical." Cambridge Comment Letter. As one of these commenters stated, Regulation S-P's requirements apply uniformly to broker-dealers and advisers, although each covered institution—including a dual registrant—will have to tailor its policies and procedures to its business.

when that notice poses a substantial risk to national security or public safety in order to align with a similar provision contained in the Public Company Cybersecurity Rules.[17]

Commenters also questioned the need for the proposed amendments in light of existing state laws that also address data breaches and raised concerns about differences between the proposed amendments and state regulatory requirements. One commenter stated that the proposed amendments were not needed because existing state laws already require firms to provide notice to individuals in the event of a data breach.[18] Some commenters stated that parts of the proposed amendments would conflict with certain provisions of state laws,[19] while other commenters stated that parts of the proposed amendments would duplicate existing state laws.[20]

As discussed more fully later in this section, while we recognize that existing state laws require covered institutions to notify state residents of data breaches in some cases, state laws are not consistent on this point and exclude some entities from certain requirements.[21] The final amendments will require notification to all customers of a covered institution affected by a data breach (regardless of state residency), in order to provide timely and consistent disclosure of important information to help affected customers respond to a data breach.[22] To that end, the final amendments will enhance investor protection in a number of ways, including by covering a

---

17 *See infra* section II.A.3.d(2).

18 *See* CAI Comment Letter.

19 *See*, *e.g.*, IAA Comment Letter 1; Letter from Computershare (June 5, 2023) ("Computershare Comment Letter"); SIFMA Comment Letter 2.

20 *See, e.g.,* CAI Comment Letter.

21 *See infra* section IV.C.2.

22 With respect to the interaction of the final rule with state law, Section 15(i)(1) of the Exchange Act (15 U.S.C. 78o(i)(1)) provides that no law, rule, regulation, or order, or other administrative action of any state or political subdivision thereof shall establish capital, custody, margin, financial responsibility, making and keeping records, bonding, or financial or operational reporting requirements for brokers, dealers, municipal securities dealers, government securities brokers, or government securities dealers that differ from, or are in addition to, the requirements in those areas established under the Exchange Act.